

Customer Discovery Interviews

100 cybersecurity professionals share their workflows, pain points, and opinions on autonomous pentest tooling.

Respondents:	100
Primary Role:	Red Team / Penetration Tester
Method:	Structured discovery interview
Date:	June 2026
Prepared by:	Chelys Security

INTERVIEW QUESTIONS

- Q1** Walk me through what a typical engagement looks like for you, start to finish.
- Q2** What takes the most time or causes the most friction in your day-to-day work?
- Q3** Have you used any AI-based or automated pentest tools? What was your experience?
- Q4** If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?
- Q5** What would fair pricing look like for something like this? Per scan, monthly sub, something else?

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

Scoping call, rules of engagement locked down, then we kick off with passive recon. I like to spend a full day on OSINT before touching anything active. Then Nmap across the asset list, Nuclei for the quick wins, and from there it depends on what surfaces. If there are AD assets in scope we go BloodHound, Kerberoast, the usual. Post-exploitation is always manual -- that is where the real findings come from.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

Report writing, without a question. I can finish an engagement in two days and spend three days writing it up. The evidence gathering, the narrative, correlating findings to CVSS -- it is the worst part of this job and nobody talks about it.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

I tried one of the commercial automated platforms a couple years ago, I won't name it. It ran Nessus under the hood with a fancy UI and called itself AI. The findings were garbage -- false positives everywhere, zero context, and it missed the actual critical path entirely. Made me skeptical of the whole category.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

Conceptually interesting, but I would need to see it run against a lab environment I built myself before I let it near a client. I would want every action logged, timestamped, and explainable. The moment it does something I did not anticipate and cannot trace back to a decision node, I am done with it. Scope enforcement is non-negotiable.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

If it genuinely replaces the grunt work -- recon, initial vuln triage, maybe first-pass exploitation -- I would pay up to \$800 a month. But it has to earn that. Monthly sub makes more sense to me than per scan because engagements vary in size.

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

We mostly do internal red team assessments. I start with credential spraying if we have an initial foothold, then lateral movement planning using BloodHound and Plumhound to visualize the attack paths. Cobalt Strike for C2. The objective is usually domain admin or a specific data target. We debrief with the blue team at the end which is actually one of my favorite parts.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

Honestly? The constant context switching. I am mid-exploitation on one thing and I have to stop to answer a client email or update a tracking sheet. The cognitive overhead of project management during an active engagement is brutal.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

I use some automation -- custom scripts, some open source stuff. I tried one AI tool that claimed to do autonomous exploitation. It got confused the moment it hit any kind of non-standard configuration. Real environments are messy and that tool clearly trained on CTF scenarios.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

I would use it for the reconnaissance and scanning phases, yes. Exploitation and post-exploitation, I would want a human making the calls. Not because I do not trust the AI per se, but because the liability question is not resolved. If the AI does something the client did not authorize, who is responsible? That answer needs to be clear before I touch it.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

Per scan does not work for me -- I do long engagements where we might run multiple passes. A monthly seat license makes sense. Maybe \$600 to \$900 a month for a senior practitioner. If it saves me 10 hours a week that math is easy.

#3

Lena Brandt

Principal Penetration Tester

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

External network test: start with subdomain enumeration, cert transparency logs, Shodan, then active scanning once the scope is confirmed. If web is in scope I do manual browsing first -- I want to understand the app before I throw tools at it. Then Burp for web, Nmap services, Nuclei templates. I try to do at least one full manual pass on every target before I rely on tooling.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

Client communication during the engagement. Scope questions, requests to add assets mid-engagement, people who suddenly go quiet when you need emergency authorization. The human stuff, not the technical stuff.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

Yes, I use Nuclei templates heavily and I would not call that AI. The actual AI-powered tools I have tried have been disappointing. They produce reports that look good until a technical person reads them. Lots of generic recommendations that do not match the actual findings.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

The idea is appealing. The reality depends entirely on how the scope enforcement works. I need to know it cannot be manipulated into going out of scope, even accidentally. And I want to see how it handles edge cases -- what does it do when it hits a WAF, or when a host starts returning weird responses? How it fails is as important as how it succeeds.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

For a tool that genuinely works I would pay \$1,000 a month. I know that sounds like a lot but I charge clients \$2,500 a day. If this saves me two days per engagement the math is obvious. Monthly subscription, with the option to pause if I am between projects.

#4

Rajesh Nair

Red Team Manager

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

We run quarterly adversary simulations for enterprise clients. Planning takes two weeks -- threat modeling, scenario design, defining success criteria. Then execution which is anywhere from two to six weeks depending on scope. We have three operators and I coordinate between them and the client point of contact. Deconfliction and debrief take another week. It is a long cycle.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

Coordinating three operators on the same engagement without stepping on each other. We use a shared wiki and a Slack channel but it is clunky. Tracking what has been tested, what has not, who owns what finding -- that project management overhead is significant.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

We evaluated a couple of platforms last year for potential use in our workflow. Most of them are good at the low-hanging fruit and terrible at anything that requires understanding context. The one that surprised me was a tool that did decent AD enumeration, but the exploitation piece was basically useless in our environment.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

For the recon and vulnerability identification phase, yes absolutely. If it can hand me a prioritized attack surface with evidence, that is valuable. I would not trust it to take exploit actions without a human in the decision loop. We have clients who would not allow it contractually anyway. But as a force multiplier for the early phases -- genuinely useful.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

Given the team size and engagement volume we run, a per-seat monthly model makes sense. If it is \$500 to \$700 per operator per month and it meaningfully accelerates the early phases, we would consider it. We would need a trial period though. Procurement is slow and I cannot sell something to leadership based on a demo.

#5

Tom Callahan

Senior Security Consultant

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I do a mix of network and web app testing. Standard stuff -- scope confirmation, asset discovery, vulnerability identification, exploitation where permitted, then the report. Web apps I always start with manual browsing and spider the app myself before running any automated scans. Network side I lean on Nmap and then decide what to chase based on what I find.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

The gap between what automated tools report and what is actually exploitable. You spend a ton of time triaging scanner output, hunting false positives, trying to figure out which of these 300 findings are real. That delta between raw scanner output and a validated finding list is where hours disappear.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

Heavy Nuclei user, some Metasploit modules. The commercial AI platforms I have seen are mostly wrappers around existing tools with a chat interface slapped on top. I am not convinced any of them actually make decisions -- they just run scripts and format the output nicely.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

For recon and triage, sure. I would use it to build the initial attack surface and then verify the interesting findings manually. Full autonomous exploitation is a harder sell. I need to know exactly what it touched and in what order so I can stand behind the report. If it does something and I cannot explain it, that is my professional liability.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

Probably \$400 to \$600 a month. I am a solo consultant most of the time so I cannot justify a big spend unless the ROI is clear. If it cuts my recon time in half -- that is maybe 8 hours per engagement -- and I do three engagements a month, that is \$300 an hour on the time saved. Then sure.

#6

Shannon Birch

Lead Penetration Tester

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I specialize in web application testing. Kickoff call, threat modeling the app with the client, then manual testing first -- always. I spend at least a day just mapping the application's authentication flows, authorization model, and data model before I run any automated tools. Burp Suite is my main tool, I have a custom extension setup I have been building for years.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

Writing proof-of-concept code for findings. When you find something like a SSRF or a deserialization bug, you have to actually demonstrate impact. Crafting that PoC, making it reliable, documenting it clearly -- that takes time. It is important work but it is slow.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

I use the Burp scanner but I do not consider that AI. I tried one of the AI web app testing tools and it found things Burp would have caught anyway and missed the business logic issues entirely. Business logic is where the real damage is and no automation handles it well yet.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

For web app testing, I am more skeptical than for network assessments. Web is contextual -- you need to understand the app's intent to find the interesting vulnerabilities. An AI that just fires payloads is not testing the same thing a skilled tester is testing. I would use it to find the obvious stuff faster and then focus my time on the logic layer. That split sounds right.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

Monthly subscription. I would say \$500 a month if it handles the surface-level stuff reliably and lets me focus on the interesting work. Per scan pricing would stress me out on large scopes.

#7

Dmitri Volkov

Offensive Security Researcher

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

My work is more research-oriented than commercial engagements -- I focus on finding novel attack chains against enterprise products. A typical project starts with documentation review, then local lab setup, then fuzzing and code review. The engagement timeline is long, months sometimes. I do not follow a standard pentest playbook.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

The documentation and reproducibility problem. When you find something new you have to document it in enough detail that someone else can reproduce it -- and do that while you are still deep in exploration mode. Switching between discovery and documentation mindset is hard.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

I use fuzzing frameworks, some custom tooling. The AI pentest tools that exist are targeting a different market than my work. They are designed for commodity assessments, not research. I do not have much experience with them for that reason.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

Not applicable to my day-to-day work but I can see the value for red teams doing volume-based assessments. For research work the whole premise is finding things automation misses. That said if it can do reliable recon and surface attack surface for me quickly, that is actually useful even in research contexts.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

Hard for me to give a number because my work is different. If I were doing commercial assessments I would probably pay \$600 to \$800 a month. For research use, maybe \$200 to \$300 a month since I would use it less intensively.

#8

Carl Estrada

Red Team Lead

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

We simulate specific threat actor TTPs agreed on with the client during planning. We get a few weeks, we have defined objectives, and we try to achieve them without tripping the blue team. It is more deliberate than a standard pentest -- slower, more operational. We document everything in real time because the debrief is as important as the exercise itself.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

Operational security during the engagement. Staying covert while still making progress is mentally exhausting. Every action has to be weighed against detection risk. The moment you trip a detection, the exercise changes character and you lose time explaining what happened.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

We use some automation for initial recon but everything from initial access onward is manual by design. The client is paying for us to behave like a real adversary and real adversaries do not run Nuclei against production systems. I have not used AI platforms for red team work.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

Depends entirely on whether the blue team knows about it. If it is a purple team exercise and both sides know, then AI automation could add value for the offensive side. For a covert red team engagement, I would not want it -- the noise profile of an automated tool would get us caught immediately. The use case matters a lot.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

For the right use case -- maybe purple teaming or initial exposure assessments -- I would pay \$700 a month. For traditional red team work, I am not the customer.

#9

Janet Morrison

Senior Penetration Tester

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

Standard external test: asset discovery with Amass and Subfinder, HTTP probing, then service-specific testing based on what is running. I try to finish the discovery phase in day one so I have the full picture before I start going deep. Then I prioritize by attack surface -- public-facing apps get attention first, then edge devices, then anything that feels off.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

Scope creep. Client adds assets during the engagement, or says something is out of scope and then changes their mind. Every time scope changes I have to restart parts of the process. It breaks the flow and adds hours.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

I use Nuclei and some custom Python scripts. I have tried one commercial AI tool on a trial basis. The findings it generated were real but not prioritized well -- it gave a critical severity to a missing HTTP header and called a known-exploited RCE medium. The severity calibration was off and I spent more time fixing the report than the tool saved me.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

Yes, for the right engagement type. External network assessments with a clear scope, I would use it. I need to see that it respects scope boundaries perfectly, that its findings are accurate enough that I am not spending an hour per finding validating, and that the output is in a format I can use directly in client reporting. Those three things would make or break the value.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

Monthly subscription, \$500 to \$700. I do six to eight engagements a month on average so per-scan pricing would hurt unless the per-scan cost is very low. Maybe \$25 to \$50 per scan as an alternative for lighter use months.

#10

Victor Huang

Principal Red Team Engineer

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

We run assumption of breach scenarios mostly -- client gives us a foothold credential and we see what we can do from there. BloodHound to map the domain, find the shortest path to the objective, then execute. Sometimes we go from employee desktop to domain admin in under an hour. The interesting work is the stuff where there are no obvious paths and you have to think laterally.

- Q2** *What takes the most time or causes the most friction in your day-to-day work?*
Keeping tooling updated. The defender side moves fast and tools that worked three months ago get caught now. Staying ahead of EDR detection, updating malleable C2 profiles, adapting OPSEC -- it is a constant maintenance burden on top of the actual work.
- Q3** *Have you used any AI-based or automated pentest tools? What was your experience?*
We test defensive tools, not offensive automation. But I have looked at some of the AI pentest platforms from a defensive standpoint to understand what our clients might face. Most of them would be caught by any decent EDR in the first five minutes. They are noisy.
- Q4** *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*
If it operates stealthily, I would be very interested. Most automated tools fail on OPSEC because they do not adapt to the environment. If this platform can behave like a human operator rather than a scanner -- adapting its technique selection based on what is running, varying its timing, avoiding known detection signatures -- then yes. Show me the OPSEC design before anything else.
- Q5** *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*
For a tool with real stealth capability, I would pay \$1,200 to \$1,500 a month. That is senior operator territory and if it performs like one, that is fair. Monthly is the only model that makes sense for ongoing red team work.

#11

Bridget O'Sullivan

Offensive Security Consultant

- Q1** *Walk me through what a typical engagement looks like for you, start to finish.*
Client-facing work, so there is a lot of project management mixed in. Scoping call, statement of work, then execution. I do a lot of cloud assessments lately -- AWS and Azure mostly. ScoutSuite, Prowler, then manual review of the IAM policies and trust relationships. The interesting findings are almost always in the trust relationships and the misconfigured roles.
- Q2** *What takes the most time or causes the most friction in your day-to-day work?*
Cloud IAM is genuinely hard to assess manually at scale. A large AWS account can have hundreds of roles and policies and finding the privilege escalation paths by hand is slow. I have built some scripts but it is still tedious.
- Q3** *Have you used any AI-based or automated pentest tools? What was your experience?*
I use Prowler and ScoutSuite which are automated but not AI. I have tried one AI cloud security tool and it was basically a wrapper around Prowler with a chat interface. Did not save me any time.
- Q4** *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*
For cloud assessments specifically I would be very interested if it can do deep IAM analysis -- not just flag public S3 buckets but actually trace the privilege escalation paths through assume-role chains. That is the hard part. If it can do that reliably, I am in.
- Q5** *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*
Per-account-per-month or per-engagement would work for cloud. Something like \$200 to \$400 per cloud environment assessed. Cloud engagements are longer so flat monthly at \$700 to \$800 would also be fine.

#12

Nathan Graves

Red Team Operator

- Q1** *Walk me through what a typical engagement looks like for you, start to finish.*
I am one of two operators at a small shop. We do about two external engagements a month and one internal per quarter. External: recon, web and network, Nuclei, Burp, manual work on the interesting bits. Internal: get physical access or a credential, then run BloodHound, look for kerberoastable accounts, check for password spraying opportunities. Pretty standard playbook.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

The gap between finding a vulnerability and proving impact. Clients want to see what an attacker could actually do -- not just that there is a SQL injection, but that we can extract the database and what is in it. That demonstration takes time and care.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

Nuclei is the main one. I played with one of the AI platforms a friend recommended. It got stuck on anything that required multi-step reasoning -- like chaining a SSRF into an IMDS hit into credential extraction. It found the SSRF, stopped, and called it done. Real exploitation rarely stops at step one.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

I would try it for sure. I am not precious about manual vs automated -- I care about what finds real vulnerabilities. My requirement would be: I can see every action it takes before or while it takes it, I can kill it with one click, and the findings it generates save me time rather than create rework. If those three things are true, I would give it a real shot.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

If I am paying out of my own pocket, \$350 to \$500 a month. If the firm pays, \$700 to \$900 is probably the ceiling before procurement gets involved. I prefer subscription over per scan because my workload is lumpy.

#13

Pavel Kolar

Senior Security Researcher

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I split time between consulting engagements and CVE research. Engagements are standard external and web app work. Research is less structured -- I pick a product, read the source or reverse the binary, look for memory safety issues or logic bugs, write a proof of concept. They are very different modes.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

The tooling gap between research and consulting. When I am doing research I have totally custom tooling. When I shift to consulting I am back to the standard toolkit which feels limiting after research work. The mental shift is also real.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

I use fuzzing frameworks -- AFL, libFuzzer -- for research. Commercial AI pentest platforms are not really relevant to my research work. For consulting I have not used them because my engagements are specialized enough that generic tools add noise.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

Interesting idea. For consulting work specifically, a good recon and initial triage layer would be genuinely useful. I often spend the first half of an engagement just building a map of the attack surface. If that is automated and accurate, I can go deeper faster. The exploitation piece I would keep manual for now.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

For the recon and triage value alone, \$400 to \$600 a month. I would not pay more unless the exploitation and post-exploitation phases are actually reliable, and that seems hard to get right.

#14

Maria Santos

Lead Red Team Engineer

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

Full adversary simulation, start to finish. We have a defined threat actor we are emulating based on the client's threat model -- we pick TTPs from that actor's known playbook and try to execute them. Initial access is the hardest part because we have to do it the way the real actor would, not just the easiest way. From there it is AD lateral movement and working toward the objective.

- Q2** *What takes the most time or causes the most friction in your day-to-day work?*
Initial access is the bottleneck. Phishing campaigns take time to set up correctly, infrastructure setup is tedious, and you have to be patient. Sometimes we spend two weeks on initial access alone. It is realistic but it is slow.
- Q3** *Have you used any AI-based or automated pentest tools? What was your experience?*
We do not use AI tools during engagements -- OPSEC reasons mainly. But I have evaluated them for what they can do and most of them would fail at initial access because they do not do social engineering and they do not handle human-facing authentication systems well.
- Q4** *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*
For a phase-gated approach where the tool handles reconnaissance and I control what happens next, yes. I would want it to be able to ingest our threat actor profile and constrain itself to those TTPs. That would make it actually relevant to our work rather than just running a generic attack.
- Q5** *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*
If it can do threat actor-specific simulation, that is a premium feature. I would pay \$1,000 to \$1,200 a month for that. Standard recon and vuln scan automation is worth \$400 to \$600.
-

#15

Scott McAvoy

Offensive Security Manager

- Q1** *Walk me through what a typical engagement looks like for you, start to finish.*
I manage a team of five so my role is more oversight now than hands-on testing. I review plans, review findings, manage client relationships, handle quality control on reports. I still get involved on complex engagements when we need a senior eye on something, but day to day I am not at the keyboard much.
- Q2** *What takes the most time or causes the most friction in your day-to-day work?*
Quality control. Getting five people to write findings in a consistent way, at a consistent severity, with evidence that actually demonstrates impact -- that is a constant battle. Our report quality varies more than I would like and I spend a lot of time editing.
- Q3** *Have you used any AI-based or automated pentest tools? What was your experience?*
I have had team members use automated tools and the main complaint is always the same: too many false positives, inconsistent severity, and the output is not in a format that plugs into our reporting workflow. We have tried three or four platforms over the years and none of them stuck.
- Q4** *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*
From a management perspective I would want it to plug into our QA workflow. If it can generate findings in our report template format, that alone would be valuable. I am less concerned about the technical autonomy question and more concerned about consistency and defensibility. Can I stand behind these findings in a client debrief?
- Q5** *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*
For a team of five, maybe \$2,500 to \$3,000 a month if it meaningfully reduces report QA time. Per seat in the \$500 to \$600 range. We would need a trial period -- I cannot buy something for the team without validating it first.
-

#16

Kenji Tanaka

Senior Penetration Tester

- Q1** *Walk me through what a typical engagement looks like for you, start to finish.*
I do a lot of IoT and embedded device testing. It is different from standard network or web -- you are often dealing with firmware you have to extract and reverse, hardware interfaces like JTAG or UART, custom protocols. The attack surface is unusual and the tooling is mostly custom or purpose-built.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

Firmware extraction is consistently the worst part. Getting the binary off the device can take longer than the actual analysis. Every device is different and there is no standard toolset.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

The AI pentest tools I know of are not relevant to hardware and IoT testing at all. They are designed for network and web surfaces. Not a criticism, just a different market.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

It is not really applicable to my main work. For the network side of IoT testing -- once you have the firmware analyzed and you know what services are running -- a tool that can automate the network-level testing would be useful. But the firmware analysis piece, which is the core of my work, is still manual.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

If it expanded to include firmware analysis capabilities, I would pay a lot for that -- there is almost no good tooling. For network-only automation, \$300 to \$400 a month, useful but not transformative for me.

#17

Ingrid Larsen

Red Team Specialist

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

We do a lot of physical and social engineering combined with network testing. The physical piece is interesting -- getting into buildings, planting devices, using that access to gain a network foothold. Then standard lateral movement from there. The report has to cover both the physical findings and the technical ones.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

Physical reconnaissance takes real time -- site surveys, understanding guard schedules, identifying entry points. You cannot automate that. It is the most genuinely human part of the work.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

Not relevant to the physical side of what we do. For the network component after physical access is gained, I use standard tools. I have not tried the AI platforms.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

The technical component after physical breach -- yes, I would use it for that. Get in the door, drop a device, have the AI platform start mapping the internal network and finding paths while I am managing the physical operation. That parallel operation would be genuinely valuable.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

If it has an internal network agent or drop-device mode, I would pay \$700 to \$900 a month. That is a specific use case though. Standard external testing, \$400 to \$500.

#18

Terrence Booker

Offensive Security Engineer

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

Mix of external network and internal AD assessments. External I run in the first day or two, build the picture, identify the exploitable surface. Internal is where the interesting work is -- I try to find the shortest path to the most sensitive data or the domain controller. Every internal network is different and that variety keeps it interesting.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

Documentation during the engagement. I hate stopping to write things down when I am in a flow state, but if I do not I forget the details and the report suffers. I have tried audio recording myself and transcribing it, which is better but still not great.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

I use some automation -- Nuclei, Nmap, a few Python scripts I wrote myself. I tried one commercial AI platform on a personal project and it was slow, noisy, and the findings were not anything I would not have found with Nuclei in a quarter of the time.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

Show me the kill switch first. I need to be able to stop it instantly with a single action and know that it actually stops -- no delayed actions, no queued commands that continue executing. If that control is reliable, then yes, I would use it for the early phases. The depth of trust builds from there.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

Monthly, \$500 to \$700. I go through periods of heavy and light work so a pause option matters. Do not lock me into a year-long contract up front.

#19

Fatima Al-Hassan

Principal Security Researcher

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

Research focused on cloud and container security. I look at Kubernetes configurations, container escape paths, cloud-to-cloud pivoting. Engagements are usually four to six weeks with a specific research question -- how can an attacker move from a compromised container to the underlying host, for example. It is targeted and deep.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

The complexity of the tooling ecosystem. For cloud and container work I am using kubectl, cloud CLI tools, custom scripts, and different tools for different providers. Switching contexts between AWS, Azure, and GKE mid-engagement is cognitively expensive.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

I use Trivy for container scanning and some cloud security tools. The AI platforms I have seen do not have meaningful Kubernetes testing capabilities yet. That is a gap in the market.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

If it supported Kubernetes and container escape testing, I would be very interested -- there is almost no good tooling for that. For general cloud testing, I would use it as a first pass to identify the low-hanging fruit and then do the deep IAM and trust relationship analysis manually.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

Cloud and container testing is a specialized market. I would pay \$800 to \$1,000 a month for a tool that genuinely understands cloud-native attack surfaces. That is less than what most cloud security tools charge for similar functionality.

#20

Ross Whitfield

Senior Red Team Consultant

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

Mostly external red team engagements for financial sector clients. Heavy compliance overhead -- everything is documented from the start, all actions logged, findings mapped to regulatory frameworks. FFIEC, PCI, sometimes SWIFT. The report is as important as the engagement itself in this sector.

- Q2** *What takes the most time or causes the most friction in your day-to-day work?*
Compliance mapping. Mapping findings to regulatory controls is slow, manual, and not something I am particularly interested in but clients require it. Every finding has to tie back to a specific control or framework reference.
- Q3** *Have you used any AI-based or automated pentest tools? What was your experience?*
I have looked at tools that automate compliance mapping and they are mostly wrong enough that I end up doing it manually anyway. The AI platforms I have evaluated for the actual testing component produce too many findings I cannot stand behind in a regulated environment.
- Q4** *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*
In financial services, the regulatory and liability context is different. I would need to know that the platform is audited, that its actions are logged in a way that satisfies regulatory requirements, and that I can produce evidence of human oversight for every significant action it takes. That is a higher bar than most platforms can meet today.
- Q5** *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*
For a compliance-aware platform, I would pay more -- maybe \$1,200 to \$1,500 a month. The regulatory documentation alone is worth something. Standard pricing of \$600 to \$800 for the technical capability.

#21

Alicia Chen

Penetration Tester

- Q1** *Walk me through what a typical engagement looks like for you, start to finish.*
Mostly web app and API testing. Start with a manual walkthrough of the application, document the endpoints, map the authentication and authorization model, then start systematic testing. I use Burp Suite as my base and add Nuclei for known CVE checks. APIs I do manual first because automated tools miss a lot of the auth bypass and BFLA issues.
- Q2** *What takes the most time or causes the most friction in your day-to-day work?*
API testing at scale. When an app has hundreds of endpoints, testing every authorization permutation manually is exhausting. I want better tooling for that specific problem.
- Q3** *Have you used any AI-based or automated pentest tools? What was your experience?*
Burp scanner, Nuclei, FFUF for directory brute force. I tried one AI API testing tool that generated test cases from the OpenAPI spec. It was actually useful for the basic cases but missed anything that required understanding the business logic.
- Q4** *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*
For API testing, yes, I would use it. Especially if it can ingest an OpenAPI spec or Postman collection and generate intelligent test cases. That would save me a significant amount of setup time. I would want to review the test cases before they run though -- just a sanity check.
- Q5** *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*
Monthly subscription, \$400 to \$600. I do not do enough volume to justify per-scan pricing and I hate being surprised by a bill.

#22

Patrick O'Brien

Red Team Operator

- Q1** *Walk me through what a typical engagement looks like for you, start to finish.*
Internal network testing mostly. I get a laptop on the client network, start enumerating, build a picture of the domain, find the interesting paths. BloodHound is essential. Then it is a mix of credential attacks, lateral movement, and trying to get to the objective without touching the honeypots.

- Q2** *What takes the most time or causes the most friction in your day-to-day work?*
Credential attacks take time to get right. Password spraying has to be done slowly enough to avoid lockouts, which means you are waiting a lot. There is a lot of hurry-up-and-wait in this work.
- Q3** *Have you used any AI-based or automated pentest tools? What was your experience?*
I wrote some custom tooling for the credential attack phase. The AI platforms I have heard of are mostly external-focused which is not my main use case. Would be curious to see one that handles internal AD environments well.
- Q4** *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*
For internal AD testing, yes, if it can automate the BloodHound analysis and path identification and then present the options to me for a go/no-go decision. I do not want it making autonomous lateral movement decisions. The risk of triggering an incident response is real and I need to be the one who decides to move.
- Q5** *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*
Probably \$600 to \$800 a month. I am on a team so if the firm is paying, that is reasonable for the right capability. Per operator makes more sense than per scan for my use case.

#23

Yasmin Rahman

Offensive Security Engineer

- Q1** *Walk me through what a typical engagement looks like for you, start to finish.*
I do application security red team work -- specifically targeting the DevSecOps pipeline. Supply chain attacks, CI/CD compromise, dependency confusion, that sort of thing. It is a narrow specialty but the attack surface is underexplored and clients are genuinely scared of it right now.
- Q2** *What takes the most time or causes the most friction in your day-to-day work?*
Keeping up with the evolving CI/CD tooling landscape. There are new tools and new attack surfaces constantly -- GitHub Actions, GitLab CI, Argo, Tekton. Every pipeline is different and I have to learn the specific tool's security model before I can attack it effectively.
- Q3** *Have you used any AI-based or automated pentest tools? What was your experience?*
I use some custom tooling for package confusion testing and some public tools like truffleHog for secret scanning. No AI platforms relevant to supply chain testing exist that I know of.
- Q4** *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*
If it handled CI/CD and supply chain testing, I would be very interested. Even a good recon layer that maps the pipeline tooling in use at a target would be useful. Right now I do that manually. The attack execution is still going to be specialized enough that I would keep it manual.
- Q5** *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*
Hard to say because the specialty is niche. \$500 to \$700 a month if it genuinely understands pipeline security. More if it has supply chain-specific attack capabilities.

#24

Greg Simmons

Senior Penetration Tester

- Q1** *Walk me through what a typical engagement looks like for you, start to finish.*
External network and some web. I have been doing this for eight years so the early phases are pretty mechanical at this point -- I have a checklist and I run it. The interesting work is always the thing the checklist does not cover, the weird edge case that takes judgment to exploit properly.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

The mechanical parts that I have been doing the same way for eight years. Subdomain enumeration, port scanning, service fingerprinting -- I could do it in my sleep. I would love to automate that away and get to the interesting parts faster.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

Yes, I use Nuclei heavily and I love it. I tried one of the AI platforms last year and was genuinely impressed with the speed of the recon phase. The exploitation piece was not reliable but the reconnaissance output was better structured than my own workflow.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

Yes, I would use it. No dramatic requirements -- just show me it is accurate on a test environment I control and that it does not do anything outside the defined scope. The exploitation autonomy I would configure conservatively at first. Ratchet it up as I get comfortable.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

Monthly, \$500 to \$700. I do not need more features than that needs to cost. If it saves me two hours per engagement and I do eight engagements a month, the math works at \$600.

#25

Nicole Rivera

Security Consultant

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

Mix of compliance assessments and technical testing. The compliance work is different -- it is more about reviewing documentation, interviewing staff, checking configuration against a standard. The technical testing is what I prefer and it is probably a third of my work.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

Compliance documentation review is mind-numbing. Reviewing 400 controls in a SOC 2 or ISO 27001 assessment is not why I got into security. I do it because clients need it but it is the least engaging part of the job.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

The AI tools I have used are mostly on the compliance side -- tools that help map evidence to controls. For the technical testing piece I use standard tooling.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

For the technical testing component, yes. If it can help me do faster external assessments when clients want both compliance and technical work in the same engagement, that is useful. I am selling time and anything that makes the technical portion more efficient lets me take on more work.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

\$400 to \$600 a month. I would want a plan that includes both the technical testing capability and maybe some compliance mapping features eventually. That would be a genuinely differentiated product.

#26

Brendan Walsh

Red Team Analyst

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I am relatively junior -- two years in. I mostly support senior operators on engagements, do my own recon work, run the standard tooling, and write up findings under supervision. Still building my methodology.

- Q2** *What takes the most time or causes the most friction in your day-to-day work?*
Keeping up with new techniques. The field moves fast and there is no formal curriculum. I learn from senior people and from CTFs but the gap between CTF skills and real engagement work is real.
- Q3** *Have you used any AI-based or automated pentest tools? What was your experience?*
I use everything the team uses -- Nuclei, Nmap, Metasploit for the modules. I am actually curious about AI tools because anything that helps me learn what to look for would be valuable at my stage.
- Q4** *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*
I would use it as a learning tool too -- see what it finds and then understand why it found it. That is probably not the primary use case you are selling but it is real. For actual engagements, I would trust it for recon and want to learn from its approach.
- Q5** *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*
Junior testers do not always control tooling budgets. If I had budget, \$300 to \$400 a month. More likely I would push for it at the team level.

#27

Sophie Laurent

Penetration Tester

- Q1** *Walk me through what a typical engagement looks like for you, start to finish.*
I am based in France and most of my clients are European mid-market companies. External testing, web apps, some cloud. GDPR adds a layer to every engagement -- we have to be mindful of what data we access and touch during testing. The regulatory context shapes how we work.
- Q2** *What takes the most time or causes the most friction in your day-to-day work?*
GDPR compliance during testing is genuinely complicated. You can hit endpoints that contain personal data as part of normal web app testing and there are real questions about what you are allowed to do with that. The legal framework for pentesting personal data is not clear in all member states.
- Q3** *Have you used any AI-based or automated pentest tools? What was your experience?*
I use standard European tooling -- Burp, Nuclei, some open source tools. The AI platforms I have heard of are US-focused. GDPR and data residency are going to be questions for any European client.
- Q4** *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*
Data residency is my first question. If client data and scan results are stored outside the EU I have a compliance problem. If you can offer EU data hosting, I become much more interested. Assuming that is solved, yes I would use it.
- Q5** *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*
European mid-market clients are price sensitive. \$400 to \$600 a month, maybe less if it is a solo consultant. The data residency piece might be worth a premium though.

#28

James Okafor

Red Team Engineer

- Q1** *Walk me through what a typical engagement looks like for you, start to finish.*
I do a lot of telecom sector testing -- mobile network infrastructure, 5G components, VoIP systems. It is a specialized area with its own protocol stack and its own attack surface. Standard pentest tooling does not cover a lot of it.
- Q2** *What takes the most time or causes the most friction in your day-to-day work?*
Protocol-specific knowledge gap in tooling. The open source ecosystem for telecom security is sparse compared to web and network. I write a lot of my own tools.

- Q3** *Have you used any AI-based or automated pentest tools? What was your experience?*
Not really applicable to telecom testing. I have used some automation for the IP network layer of telecom infrastructure but nothing that understands SIP, SS7, or 5G-specific protocols.
- Q4** *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*
For the IP network layer of telecom infrastructure, I would consider it. Anything above that is too specialized for a general-purpose tool right now. I would want to see how it handles unusual protocols before trusting it near production telecom systems.
- Q5** *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*
\$400 to \$500 a month for the IP network layer capability. The telecom-specific stuff would need to be a specialized module and that could command more.

#29

Rebecca Yoon

Senior Security Researcher

- Q1** *Walk me through what a typical engagement looks like for you, start to finish.*
I split time between academic research and consulting. The research side is long-horizon stuff -- threat modeling new architectures, publishing papers. The consulting side is shorter engagements, mostly architecture reviews and threat modeling rather than hands-on testing.
- Q2** *What takes the most time or causes the most friction in your day-to-day work?*
The theory-to-practice gap. In research you think in idealized systems. Consulting is messy real systems with legacy components and weird configurations. Translating research insights into actionable consulting recommendations is harder than it looks.
- Q3** *Have you used any AI-based or automated pentest tools? What was your experience?*
I follow the AI security tooling space academically. The interesting research question is whether LLM-based agents can reason about multi-step attack chains, not whether they can run Nuclei faster. The current generation of tools is mostly the latter.
- Q4** *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*
I would be interested from a research angle as much as a practical one. If it can genuinely reason about attack chains rather than just running a checklist, that is a different and more interesting product. I would use it on research projects to evaluate its reasoning.
- Q5** *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*
For research access, maybe \$200 to \$300 a month. For consulting use, \$500 to \$700. Academic discount programs would be appreciated.

#30

Tyler Fox

Offensive Security Consultant

- Q1** *Walk me through what a typical engagement looks like for you, start to finish.*
I specialize in healthcare sector clients. HIPAA context shapes everything -- we are careful about what patient data we touch, we have BAAs in place before we start, and the report has to map findings to HIPAA security rule controls. The technical work is standard but the regulatory wrapper is significant.
- Q2** *What takes the most time or causes the most friction in your day-to-day work?*
Healthcare clients are often technically understaffed and the testing surfaces reflect that -- lots of legacy systems, outdated software, misconfigurations everywhere. There are so many findings that triaging and prioritizing for an organization with limited remediation capacity is genuinely hard.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

I use standard tooling. The AI platforms I have looked at do not have HIPAA-aware reporting. That is a missing feature for the healthcare market.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

HIPAA mapping in the findings and report would be a differentiator for me. If it can produce findings that are already mapped to the HIPAA Security Rule technical safeguards, that saves me significant report time. Technical capability is table stakes, compliance-aware reporting is the differentiator.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

\$600 to \$800 a month. Healthcare clients pay reasonable rates and I can justify the tooling cost easily if it reduces report time.

#31

Anisha Patel

Red Team Specialist

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I focus on Active Directory attacks and lateral movement. Most of my engagements are assumed breach -- client gives me a low-privilege account and I try to get to domain admin. BloodHound, PowerView, various Impacket scripts. The methodology is fairly settled but each environment has different nuances.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

The time from initial BloodHound output to a prioritized attack plan. BloodHound gives you everything at once and figuring out the best path takes analysis. I have gotten faster at it but it is still the bottleneck in the early AD phase.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

I have used some automation scripts for the AD enumeration phase but nothing with real AI behind it. Custom Python and PowerShell mostly.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

AD attack path analysis is where I would most want AI assistance. If it can take a BloodHound output and give me a ranked list of attack paths by feasibility and impact, that is concrete value. The execution itself I would keep manual -- AD is too high-risk for autonomous lateral movement.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

For AD-focused capability specifically, \$600 to \$800 a month. If it does it well that is probably saving me an hour per engagement minimum.

#32

Luis Moreno

Penetration Tester

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I am in Mexico City working mostly with Latin American clients. The client base ranges from mature enterprises to companies doing their first pentest. For the less mature clients a lot of the engagement is educational -- explaining what we found and why it matters. The technical work is often secondary to the communication.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

Communication gaps with non-technical stakeholders. I find something critical and I have to explain it to a CTO who does not have a security background. That translation work is time-consuming and important.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

I use Nuclei, Burp, Nmap, standard stuff. No AI platforms -- they are mostly priced for US or European markets and marketed there.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

If it produced executive-friendly summaries of findings automatically, that would be genuinely valuable for my client mix. The technical findings are the easy part, the business impact narrative is what takes time to write for a non-technical audience.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

Pricing for Latin American market is a concern. US pricing is prohibitive for my clients to absorb. If there is regional pricing, \$200 to \$350 a month would work for me. If not, I probably cannot justify it.

#33

Claire Thompson

Senior Red Team Operator

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

Financial services red team. Very structured -- defined objectives, defined rules of engagement, defined notification procedures. Every action is logged in real time in a shared tracker that the white team can see. Nothing happens without documentation. It is more controlled than most red team work.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

The documentation-as-you-go requirement. I cannot just work and document later -- the white team is watching the tracker in real time. That breaks the operational flow significantly.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

The platform we use internally handles some automation but it is bespoke. I have not evaluated commercial AI platforms.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

In a financial services context the audit trail is everything. I would want every AI action logged to a standard I could hand to a regulator -- timestamp, action type, target, outcome, decision rationale. If the platform can provide that, I become much more interested. Without it, the liability exposure is too high.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

For a compliance-grade audit trail, I would pay \$1,000 to \$1,200 a month. That is the price of compliance and it is worth it if the documentation requirement is satisfied.

#34

Marcus Lin

Offensive Security Engineer

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I do a lot of mobile application testing -- iOS and Android. Static analysis with MobSF, dynamic analysis with Frida, manual code review. The attack surfaces are different from web and the tooling ecosystem is more fragmented.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

Dynamic analysis setup is slow. Getting Frida working in a real app with certificate pinning and root detection is multiple hours of environment setup before you can actually test. That friction is real.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

MobSF for automated analysis. I have not seen a good AI-powered mobile testing tool. The static analysis space is underserved.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

If it had mobile app testing capability -- automated SSL unpinning, Frida script generation, dynamic analysis -- I would be very interested. Mobile is an area where automation would genuinely help because so much of the setup is mechanical.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

\$500 to \$700 a month if it covers mobile well. Right now I would probably not use a network-focused tool for my work.

#35

Danielle Kowalski

Red Team Analyst

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I am fairly early in my career and working across external and web app testing. I am still developing my methodology and I use a mix of the team's standard tooling and techniques I pick up from conferences and online courses.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

The learning curve is the main challenge. There is so much to know and the field changes fast. I sometimes feel like I am running to stand still.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

I use everything the team uses. I am actually enthusiastic about AI tools as a learning mechanism -- I want to see how a system would approach something and then compare it to my own thinking.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

I would use it and I would treat the first several engagements as a chance to calibrate. Does it find the same things I find? Does it find things I miss? Does it follow paths I would not have considered? That comparison process would accelerate my development.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

If I were paying personally, \$200 to \$300 a month. Team budget, \$500 to \$600 is reasonable.

#36

Amir Khaled

Senior Penetration Tester

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

External and internal assessments in the Middle East region, mostly UAE and Saudi Arabia. Clients range from government entities to financial institutions. The regulatory environment is unique -- SAMA, NESA, various national frameworks. Report format requirements vary by client and by regulation.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

Regulatory mapping, same as many of my colleagues. SAMA has specific requirements, NESA has others, and I am often writing the same finding three times for three different frameworks. Automation there would help significantly.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

Standard tooling. The AI platforms are not localized for the region and the compliance frameworks they map to are not the ones I work with.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

If it supported SAMA and NESA compliance mapping I would be immediately interested. Those are underserved markets. Technical capability I would want to verify on a demo environment before using it with a government client.

- Q5** *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*
\$700 to \$1,000 a month for the right regulatory mapping capability. Government clients pay well and I could justify the tool cost easily.

#37

Hannah Bennett

Security Researcher

- Q1** *Walk me through what a typical engagement looks like for you, start to finish.*
Academic background, now doing applied security research and some consulting. I study how attackers make decisions -- the cognitive side of the offensive security process. My consulting work is more security program assessments than hands-on testing.
- Q2** *What takes the most time or causes the most friction in your day-to-day work?*
The lack of good empirical data on attacker behavior. A lot of security is based on intuition and anecdote. Rigorous data on how attacks actually unfold is rare.
- Q3** *Have you used any AI-based or automated pentest tools? What was your experience?*
I study AI security tools as research subjects as much as use them. How AI tools make decisions about what to attack and how is interesting to me from a behavioral perspective.
- Q4** *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*
Genuinely curious about the decision-making model. What does the AI use to prioritize which attack paths to pursue? Is it RL-based? Is it prompt-driven? How does it handle uncertainty? Those questions matter to me both professionally and personally.
- Q5** *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*
\$300 to \$500 a month, more from a research perspective. I would probably not use it for commercial work as my consulting is not hands-on testing.

#38

Carlos Espinoza

Red Team Lead

- Q1** *Walk me through what a typical engagement looks like for you, start to finish.*
I lead a three-person team doing red team and adversary simulation for mid-market clients. Our sweet spot is clients who are past their first compliance checkbox and want to actually understand their risk. We run two or three engagements simultaneously and manage them on a shared platform.
- Q2** *What takes the most time or causes the most friction in your day-to-day work?*
Context switching between engagements. When you are running three concurrent projects you are constantly shifting your mental model. Each client has a different environment, different scope, different risk tolerance. The cognitive overhead is significant.
- Q3** *Have you used any AI-based or automated pentest tools? What was your experience?*
We use a mix of commercial and open source. Tried one AI platform for a client proof of concept -- it impressed them in the demo and then disappointed in execution. The gap between demo-ready and production-ready is real.
- Q4** *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*
I would use it for the initial phases on all engagements simultaneously -- kick off recon on three engagements at once and have the results ready when I have operator capacity to go deeper. That parallelism is genuinely valuable for a team like mine.

- Q5** *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*
\$1,500 to \$2,000 a month for a team license, unlimited engagements. Per scan does not work when I am running concurrent projects. Monthly flat rate is the only model I would buy.

#39

Sarah Novak

Offensive Security Consultant

- Q1** *Walk me through what a typical engagement looks like for you, start to finish.*
I focus on cryptographic implementation review and protocol analysis. TLS configuration, JWT implementation, certificate pinning, custom cryptographic protocols. It is a narrow specialty but every organization has some cryptographic system and many of them are implemented badly.
- Q2** *What takes the most time or causes the most friction in your day-to-day work?*
Automated tools do not understand cryptography well. Scanners can check whether TLS 1.0 is enabled but they cannot evaluate whether a JWT signature is using a weak key or whether a custom protocol has semantic weaknesses. That analysis is manual.
- Q3** *Have you used any AI-based or automated pentest tools? What was your experience?*
I use some tooling for TLS scanning -- testssl.sh, sslyze. The AI platforms I have seen do not go deep enough on cryptographic analysis to be relevant to my specialty.
- Q4** *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*
If it had strong cryptographic analysis capabilities -- JWT manipulation, TLS misconfiguration identification beyond the obvious, custom crypto pattern detection -- I would be interested. Without that it is not really useful for my main work.
- Q5** *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*
\$400 to \$600 for the cryptography-specific capabilities. More if it can do real JWT and OAuth testing at depth.

#40

Ryan McCarthy

Penetration Tester

- Q1** *Walk me through what a typical engagement looks like for you, start to finish.*
I am a generalist -- web, network, cloud, AD -- I cover whatever the engagement requires. I have been doing it for five years so I have breadth if not deep specialty. My clients are mostly SMBs who need someone who can cover everything in a short engagement.
- Q2** *What takes the most time or causes the most friction in your day-to-day work?*
Being a generalist means I am always hitting the edge of my depth in some area. I know a lot about most things but I am not as deep as a specialist in any one area. That limits what I can find in specialized systems.
- Q3** *Have you used any AI-based or automated pentest tools? What was your experience?*
I use the full standard toolkit. I have tried two AI platforms -- one was too slow, one had too many false positives. Neither saved me net time.
- Q4** *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*
For SMB work where I am covering a wide surface in a short time, a tool that can do the broad initial sweep and let me focus on the interesting findings would be valuable. I would use it as a force multiplier, not a replacement. My clients cannot afford long engagements so efficiency matters.
- Q5** *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*
At SMB scale, \$300 to \$500 a month. I need to keep my margins healthy. If I can add more clients because the mechanical work is faster, the ROI works.

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

Red team work for retail and e-commerce clients. PCI DSS in scope for almost everything. The attack surface is usually web applications, payment processing integrations, and internal systems. We have specific PCI objectives in mind going in.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

PCI reporting. The finding format requirements for PCI are specific and the mapping to PCI DSS controls has to be precise. Getting a finding wrong in PCI context can have real compliance consequences for the client.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

Standard tooling, some PCI-specific compliance tools. No AI platforms with PCI-native reporting that I have found.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

PCI-aware reporting would be significant for me. If findings come out already mapped to PCI DSS controls with the right language, that saves substantial report time. Technical capability I would validate before using near a cardholder data environment.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

\$700 to \$900 a month if it handles PCI reporting well. That is a meaningful time savings and the cost is easily absorbed.

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I do security program development as much as technical testing. I come in, assess where a client is in their security maturity, do a technical assessment to validate, and then help them build a roadmap. The technical work supports a broader consulting engagement.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

Scope of work management. When you are doing both strategic and technical work on one engagement the scope tends to expand in both directions. Managing that without burning out or going over budget is an art.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

Standard technical tooling. The AI platforms I have evaluated are purely technical -- they do not help with the strategic side which is half of my work.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

For the technical assessment component, yes. If it gives me a rigorous technical baseline faster, I can spend more time on the strategic and advisory work that clients actually value most. That is a real benefit.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

Monthly, \$500 to \$700. The technical tool is only part of my offering so I would not pay a premium on it. The value is in freeing time for higher-value work.

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

Internal AD testing and lateral movement is my specialty. I love the puzzle aspect of it -- finding the unexpected privilege escalation path, the misconfigured trust relationship, the service account with way too many permissions. Every AD environment is a different puzzle.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

The time to get to the interesting stuff. The first few hours of any internal engagement are mechanical -- run BloodHound, enumerate shares, check for obvious credential issues. I want to get to the non-obvious stuff faster.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

I use BloodHound, Impacket, CrackMapExec extensively. Some custom Python. No AI platforms yet but I am curious.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

For the mechanical early phase of AD testing, yes absolutely. If it can get me to the interesting paths faster, I am in. I would want it to show me its work -- not just tell me there is a path to domain admin but show me the step-by-step chain it found. That way I can validate and then execute manually.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

Monthly, \$500 to \$700. The ROI is clear if it compresses the early phase significantly.

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I work at an MSSP doing continuous attack surface management. We have ongoing retainer clients -- we are always running some level of assessment, monitoring for new exposure, validating remediations. It is less discreet engagements and more continuous coverage.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

Keeping up with new assets. Clients add infrastructure constantly and we are supposed to cover it. The continuous discovery problem is real -- how do you know when a client has added something new that you should be testing?

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

We use some commercial attack surface management tools for the continuous discovery. They are automated but not AI in any meaningful sense. The automated testing piece is still pretty basic.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

For continuous attack surface management, autonomous testing is a natural fit. If it can monitor for new assets, test them automatically, and alert me to new findings without requiring me to manually kick off a scan, that would transform the retainer model. That is genuinely compelling.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

For a retainer model, \$1,000 to \$1,500 a month for continuous coverage across a client portfolio makes sense. Per scan does not work for continuous -- you need a flat rate.

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I am in Germany and most of my work is for German Mittelstand companies -- medium-sized manufacturers and engineering firms. These clients often have interesting OT and IT convergence attack surfaces. The IT/OT boundary is usually poorly defined.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

The IT/OT boundary assessment is complex and risky. You cannot just run a scanner against an OT network. The equipment is often fragile, the protocols are unusual, and a misconfigured test action can cause real production impact.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

I use tools specifically designed for OT -- some Nmap scripts, Siemens and Shodan integrations. Standard pentest tools are too risky near OT.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

For the IT side of an IT/OT engagement, yes. For anything near the OT network, no -- the risk of disrupting production equipment is too high for an automated system without deep OT-specific guardrails. The IT side use case is real though.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

For the IT component, \$500 to \$700 a month. OT-specific capability would need to be a specialized add-on with very different pricing and very different safety requirements.

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I try to automate as much of the engagement as possible. My philosophy is that anything mechanical should be scripted. I have a personal toolkit that handles recon, initial scanning, and report template generation. I am always looking for new tools to add to it.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

Things I have not automated yet. Every time I find myself doing the same thing manually three times, I write a script. But there is always more -- the things that are hard to script are the ones that still take the most time.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

I have used several AI tools and I am not a skeptic. Nuclei is great, I have experimented with some LLM-based tools for finding logic bugs. The quality varies but I am a believer in the direction even when the current tools disappoint.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

I would use it from day one. My requirement is mostly documentation -- I want to understand the decision logic so I can calibrate and improve over time. If it does something interesting I want to know why. Show me the reasoning, not just the output.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

Monthly \$600 to \$800. I would honestly pay more if it is genuinely good. The ROI calculation is simple -- if it saves me eight hours per engagement and I do five engagements a month, at my rate that is several thousand dollars of time saved.

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I try to stay on the cutting edge of tooling. I contribute to open source offensive tools in my spare time, test new techniques from conference talks, and generally enjoy the tooling side of the craft as much as the actual testing. Good tooling makes good testing.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

The tooling maintenance burden. When you maintain custom tools and also try to stay current with the community tooling, the time investment is significant. I probably spend 20% of my time on tooling rather than testing.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

I have tried most of the AI-assisted tools that have come out in the last two years. Some are impressive for specific use cases, most are overhyped. The ones that let me extend them -- add my own modules or techniques -- are the ones that stick around in my workflow.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

If it is extensible I am very interested. Let me add my own techniques, my own tooling, my own payload templates. A platform that can run the AI coordination layer while I plug in my specialized tools would be genuinely powerful. That is the architecture I would want.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

Monthly subscription, \$700 to \$900. I would pay more for extensibility -- the ability to add custom modules is a meaningful differentiator.

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I do CTFs in my spare time which bleeds into my professional approach -- I am always thinking about chaining findings and finding the non-obvious path. My professional work is external and web, standard engagements, but I try to bring the CTF mindset of pushing until you find the unexpected.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

The constraint of scope. CTFs you can do anything, professional work you have defined boundaries. Sometimes the interesting finding is just outside the scope boundary and you cannot chase it. That is frustrating.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

I have used every AI tool I could get my hands on. They are better for CTF problems than real engagements because real environments have more noise. But the gap is closing. I tried one that used an agent loop and it was clearly smarter than the rule-based tools.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

I would use it immediately and push it hard. I want to see where it breaks and where it surprises me. That is how I evaluate tools -- put them in an environment with a known answer and see if they find it. If it finds things I would have missed, I am a convert.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

Whatever the pricing is I would probably just pay it. \$500 to \$700 a month seems reasonable. Per scan for lower volume use cases could work too.

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I focus on cloud and hybrid environments -- AWS, Azure, on-prem AD connected to cloud. The interesting attacks are almost always at the hybrid boundary -- how do you go from a cloud compromise to on-prem or vice versa. That attack path is underexplored by most clients.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

The complexity of mapping the hybrid boundary. Understanding how identity flows between cloud and on-prem is genuinely complicated and the tooling does not always show you the full picture.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

I use ScoutSuite, some custom tooling for Azure. I have experimented with AI tools for cloud and they are getting better. The problem is that cloud environments change fast and the tools trained on last year's attack surface miss current misconfigurations.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

Cloud plus on-prem in one tool would be great. I currently switch between different tools depending on the environment and the context-switching is annoying. A unified attack surface view with autonomous testing would be compelling.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

Monthly \$700 to \$900 for a cloud-plus-hybrid capable tool. That is less than what most standalone cloud security tools cost.

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I research offensive tooling and novel attack techniques. Publishing, presenting at conferences, contributing to the community. My day-to-day is experiments, reverse engineering, prototype exploitation. Very little structured engagement work.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

Publishing is the hardest part. Writing a paper or a conference talk is a completely different skill from doing the research. The communication of findings is as important as the findings themselves but it is not what most people in this field are trained for.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

I track the AI offensive tooling space closely. The academic work on LLM-based pen testing is interesting even where the practical tools disappoint. The research question of whether LLMs can reason about multi-step exploit chains is open and important.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

I would participate in a beta or early access program primarily to evaluate the reasoning quality. Whether it can discover non-obvious attack chains -- that is the interesting question. If it finds things I did not, that is genuinely impressive and publishable.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

For research access I would pay \$200 to \$300 a month. I am not doing commercial volume but I could generate useful feedback and potentially academic coverage which has marketing value for you.

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I joined red team work from a development background and I bring a developer's mindset to it. I find code-level vulnerabilities faster than most because I understand how developers make mistakes. I am also more comfortable writing custom tooling.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

The communication gap with developer teams. When I find a vulnerability in their code I can explain the root cause at the code level, but getting them to prioritize fixing it over shipping features is a different skill set that I am still developing.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

I have written my own tooling for SAST-assisted manual review. The AI coding assistants I use for tool development are genuinely useful -- better code, faster prototyping. For offensive testing specifically I have not found an AI tool that adds much yet.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

If it could integrate with code repositories and combine static analysis with dynamic testing -- finding a vulnerability in code and then automatically validating it against the running application -- that would be a genuinely novel capability. Is that on the roadmap?

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

For a code-plus-runtime integration, \$700 to \$900 a month. That is a differentiated capability that justifies a premium.

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I have been doing this for a decade and I embrace automation enthusiastically. The job has changed a lot -- ten years ago everything was manual because the tooling was primitive. Now the tooling is good enough that refusing to automate is just making yourself slower.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

The things that are still manual because the tooling has not caught up. Exploiting certain logic vulnerabilities, chaining multi-step attack paths in complex applications -- the automation has not gotten there yet and those are the things that take my time.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

I use a lot of automation and I am a positive reference for tools that work. I have seen three or four AI tools come and go -- the ones that failed, failed because they overpromised and underdelivered. I have zero patience for demos that do not reflect real performance.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

I would use it day one. My threshold is simple -- run it against a target I know well and see if the findings match what I would find. If it finds things I would not have found, I am immediately a customer. Show me real performance on a real target, not a demo environment.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

Monthly subscription, \$700 to \$1,000. For something that genuinely works, price is not the constraint. Capability is the constraint.

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I recently transitioned from blue team to red team. The perspective shift is significant -- I spent years building detections and now I am trying to evade them. That background makes me think differently about OPSEC and about which attack techniques are truly dangerous versus which ones are just noisy.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

Remembering to think offensively. After years of blue team work my instinct is still to ask how this would be detected. That is useful for OPSEC but it sometimes slows down my offensive thinking.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

I am positive on AI tools partly because I have seen how blue teams struggle to keep up with the volume of alerts. A tool that generates realistic attack noise in a controlled way helps blue teams tune their detections. There is a purple team use case here that is underexplored.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

For purple team exercises I would use it enthusiastically. Have the AI run a realistic attack scenario while the blue team watches and refines their detections. That is a concrete use case that I can sell to a CISO. The autonomous external pentest use case is compelling too but the purple team application is an easier sell.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

Monthly \$600 to \$800 for general use. For a specific purple team module, organizations would pay more -- maybe \$1,500 to \$2,000 for a structured purple team exercise package.

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I prioritize interesting engagements over volume. I turn down commodity external network scans and focus on red team work with interesting objectives. I would rather do one great engagement a month than five mediocre ones.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

Finding enough interesting engagements. The market wants commodity pentests but I want to do real red team work. That tension is real.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

I am enthusiastic about AI tools because they could handle the commodity work that I currently turn down -- and allow me to take it without it consuming my time. Automated commodity + manual interesting is an interesting business model.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

The commodity pentest automation case is genuinely compelling to me as a business model. If I can sell commodity engagements with the AI doing the work and I review and sign off, that is a revenue stream I currently do not have access to without compromising quality.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

Monthly \$600 to \$800. If I am reselling it as a service, the economics need to work -- I need to charge the client something above what I pay for the tool. At \$700 a month and a \$2,000 commodity engagement, that math works fine.

#55

Nina Petrov

Security Researcher

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I research browser security -- memory corruption, sandbox escapes, renderer exploitation. Very specialized, very manual. I write a lot of JavaScript and C++ fuzzing harnesses.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

Fuzzing compute cost. To fuzz a browser properly you need a lot of CPU and a lot of time. The infrastructure investment is significant.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

Fuzzing frameworks obviously. The AI pentest tools are not relevant to browser exploitation research. Different world.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

Not relevant to my direct work but I would be curious to see how the system reasons about web application vulnerabilities. Browser exploitation and web application security are different things but there is some overlap in the reasoning about trust boundaries.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

Not my use case but if I were doing web testing, \$500 to \$700 a month seems fair for a capable tool.

#56

Omar Abdullah

Penetration Tester

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I am relatively new to professional pentesting -- about 18 months -- but I came in with a strong CTF background. I do external and web app work and I am getting faster every engagement. The learning curve is steep but I am enjoying it.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

Knowing what I do not know. I sometimes miss vulnerabilities not because I lack the technique but because I do not know to look for them. Experience is the main gap and it takes time to build.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

I use all the standard tools and I would try any AI tool I could get my hands on. I have experimented with some free options. My feedback is that they are good at finding the things I already know how to find.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

I would use it as a learning accelerator. Watch what it does, understand why, compare to my own approach. If it finds something I would have missed, I learn from that. If it misses something I found, I learn something about its limitations. Both are valuable.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

As a junior tester I am price sensitive. \$200 to \$300 a month would be what I could justify personally. Maybe \$500 if the team is paying and it meaningfully improves my productivity.

#57

Vivian Cheng

Offensive Security Engineer

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I focus on supply chain and third-party risk. Testing vendor software that clients have integrated, finding vulnerabilities in components they did not write. It is a different mindset -- you are attacking something the client did not build and has limited visibility into.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

Getting access to the software in a way that allows testing. Vendors are not always cooperative about providing test environments and NDAs can limit what you can do with what you find.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

I use SCA tools for dependency analysis and some custom tooling for dynamic testing of third-party integrations. The AI pentest tools are not really designed for this use case.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

If it could handle third-party software testing -- ingesting a binary or a software package and producing an attack surface analysis -- that would be interesting. Right now I have to set up a test environment for every third-party component I want to test.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

\$500 to \$700 a month. Supply chain testing is becoming more common so the market for this is real.

#58

Blake Turner

Red Team Lead

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I run a two-person red team at a mid-size tech company. We do quarterly exercises, continuous attack surface monitoring, and support the incident response team with adversary perspective during real incidents. The internal red team role is broader than external consulting.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

Getting leadership buy-in for exercises. Internal red teams have to constantly justify their existence and their budget. Every engagement needs a story about what we found and what would have happened if an adversary did this instead of us.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

We use all the commercial tools we can justify budget for. I have been pushing for an AI-assisted platform for six months. The argument I am making to leadership is efficiency -- the same headcount doing more coverage.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

I would use it to justify expanding our coverage without hiring another headcount. That is the business case I can sell internally. If the tool can credibly cover more attack surface, I can make the ROI argument to my CISO.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

For an internal red team, annual licensing makes more sense than monthly -- budget cycles are annual. Probably \$12,000 to \$15,000 per year for a two-person team. That is a headcount conversation reframed as a tooling conversation.

#59

Alannah Murphy

Senior Security Researcher

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I study offensive AI -- how AI systems can be used for attack and how defenders can detect AI-generated attack patterns. It is early-stage research but the field is moving fast.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

The dual-use nature of the research. Everything I publish about how AI can be used offensively is also a blueprint for defenders, but it is also a blueprint for attackers. That responsibility weighs on me.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

I study AI pentest tools as research subjects, not just as practitioners. The papers published in the last year on LLM-based penetration testing are interesting and I have followed the open source projects closely.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

I am enthusiastic in principle. My research question is whether the AI is making genuine decisions or executing an elaborate script. The distinction matters for understanding what the technology actually is. If it is genuine agentic reasoning, that is a different category of capability.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

For research access, \$200 to \$300 a month. I could also potentially collaborate on evaluations and publish findings which could have marketing value.

#60

Jordan West

Red Team Engineer

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I work at a startup doing offensive security and I wear a lot of hats -- I do the testing, write the reports, manage client relationships, handle the tooling. It is a lot but I prefer the variety to being siloed.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

The context switching between technical work and client-facing work. When I am deep in an exploitation chain and I have to stop for a client call, it is hard to get back into the zone.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

I have tried several AI tools and I am more positive than average. The key insight I have developed is to not use them as replacements for technique but as force multipliers for the mechanical stuff. Set those expectations and they deliver.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

I would use it to handle everything before the interesting manual work. Recon, initial scanning, first-pass triage -- automate that. Then I come in for the exploitation, the post-exploitation, the narrative. That division of labor makes sense.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

For a startup, \$500 to \$700 a month. If it genuinely handles the mechanical work, that is probably ten hours a week I get back. At any reasonable rate that pays for itself.

#61

Felix Wagner

Independent Security Researcher

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

Bug bounty is my main income. I specialize in web applications and APIs, focus on specific programs where I know the technology stack. I have a list of programs I cycle through and I build up program-specific knowledge over time. The depth is as important as the breadth.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

Scope. Programs keep narrowing scope and adding exclusions. The most interesting attack surfaces are often out of scope. I spend significant time reading scope documents to understand what I can actually test.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

I use Burp, Nuclei, some custom scripts. I have tried a few AI tools on bug bounty programs and the results were disappointing -- they find the same things the program has probably already seen dozens of times. The signal-to-noise ratio is not better than just running Nuclei.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

On bug bounty you have to be careful about automated testing. Many programs have explicit prohibitions or rate limits. I would need to know that it respects program-specific restrictions and does not generate the kind of noisy traffic that gets you banned from a program.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

Per-scan would make sense for bug bounty because my testing is intermittent. Maybe \$30 to \$50 per target or \$200 to \$300 a month with a reasonable scan limit. Programs pay better than they used to but per-scan pricing needs to be very low to work.

#62

Aria Saito

Bug Bounty Researcher

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I focus on authentication and authorization bugs. OAuth flows, SSO implementations, SAML assertions, JWT manipulation. These are almost always manual finds because automated tools do not understand the intent of auth systems, just the mechanics.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

Coverage versus depth. I can skim the surface of many programs or go deep on a few. Deep has better payout probability but requires more time investment before you see results. The resource allocation decision is constant.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

I do not use AI tools for the auth-focused work I do. The bugs I find require understanding the business logic of the auth flow and that is still human territory.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

For auth testing specifically, I would be interested if it could model the intended auth flow and then look for deviations. That is a much harder problem than running payloads but it is where the real bugs are. Is that on the roadmap?

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

If it cracked auth testing, I would pay whatever it costs. Probably \$300 to \$500 a month would be fair for the right capability.

#63

Connor McLeod

Independent Penetration Tester

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I split time between bug bounty and private consulting. The consulting pays better per hour but the bug bounty is more fun. I do web app mostly, some API testing, occasional mobile.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

Marketing and finding clients. Technical work is not the bottleneck -- finding good clients who pay well and have interesting targets is. I spend more time on business development than I would like.

- Q3** *Have you used any AI-based or automated pentest tools? What was your experience?*
Nuclei, Burp, some custom tooling. Tried two AI platforms on bug bounty targets and neither produced findings I would submit. They find things the programs have fixed and things that are not real.
- Q4** *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*
If it could meaningfully improve my bug bounty hit rate, I would be interested. But the bar is high -- I need it to find things that have not been found before, not things every other researcher has already submitted. The commodity findings are worthless on a mature program.
- Q5** *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*
\$200 to \$350 a month for bug bounty use. My income is variable so low fixed costs are important.
-

#64

Leila Farsi

Bug Bounty Researcher

- Q1** *Walk me through what a typical engagement looks like for you, start to finish.*
I focus on cloud misconfiguration bugs in corporate assets. S3 buckets, exposed APIs, cloud metadata service issues. The low-hanging cloud fruit is still out there in surprising quantities. I have had some good payouts on misconfigured cloud assets.
- Q2** *What takes the most time or causes the most friction in your day-to-day work?*
Staying ahead of the easy finds. Programs fix the obvious cloud misconfigs quickly once they are reported. I have to keep finding new angles on cloud attack surfaces to stay productive.
- Q3** *Have you used any AI-based or automated pentest tools? What was your experience?*
Grayhat tools for recon -- Shodan, Censys, some custom tooling. The AI platforms I know are not optimized for cloud misconfiguration discovery specifically.
- Q4** *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*
If it automated cloud asset discovery and misconfiguration checking at scale, that is directly useful for my work. That is basically what I do manually now. If it finds valid misconfigs I can report, I would pay for it.
- Q5** *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*
Per-scan pricing works for cloud -- I do targeted discovery, not broad scanning. Maybe \$40 to \$60 per cloud account scanned or \$250 to \$350 a month.
-

#65

Drew Patterson

Independent Security Researcher

- Q1** *Walk me through what a typical engagement looks like for you, start to finish.*
I focus on blockchain and smart contract security. Solidity code review, finding reentrancy bugs, logic errors in DeFi protocols. It is very different from traditional pentesting -- the bug classes are specific to the execution model.
- Q2** *What takes the most time or causes the most friction in your day-to-day work?*
The learning curve of smart contract security is steep. The bugs are subtle and the execution model is unusual. Most traditional security thinking does not directly apply.
- Q3** *Have you used any AI-based or automated pentest tools? What was your experience?*
Smart contract analysis tools -- Slither, Mythril, Echidna. Not relevant to traditional AI pentest tools.
- Q4** *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*
Not applicable to my work but there is a parallel question of AI-assisted smart contract auditing that is interesting. Tools that can reason about execution semantics and find logic bugs in DeFi protocols -- that is a different product but a real need.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

Not my market but if you are thinking about blockchain security, there is a large and underserved market there.

#66

Sanjay Mehta

Bug Bounty Hunter

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I do bug bounty full time and I am in the top tier on two major platforms. I specialize in server-side vulnerabilities -- SSRF, XXE, deserialization, path traversal. Web app focus almost entirely.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

Program saturation. The top programs have thousands of researchers on them and the obvious vulnerabilities are found quickly. I have to go deeper and look harder than most researchers to find anything in mature programs.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

I have tried automation but it does not help with the kind of bugs I find. SSRF and XXE require understanding the application's trust model and how it processes external inputs -- that is not something current automated tools handle well.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

If it could do SSRF and XXE testing at a meaningful depth -- not just fuzzing common parameters but understanding how the application fetches external resources and what trust boundaries exist -- I would be interested. That is a hard problem. Does it actually do that or is it fuzzing?

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

\$200 to \$300 a month for bug bounty use. My income is entirely variable so I need to be able to turn it off when a payout season is slow.

#67

Camille Renard

Independent Security Researcher

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I focus on open source software -- finding vulnerabilities in widely used libraries and frameworks. It is a different model from bounty hunting on specific programs. The impact potential is high because a bug in a popular library affects many downstream applications.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

Responsible disclosure is complicated for open source. There is no established bounty program, the maintainers have varying responsiveness, and coordinating disclosure across the downstream affected projects is difficult.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

SAST tools, fuzzing, some manual code review. The AI pentest platforms are web-app and network-focused, not library security-focused.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

Not directly applicable. The code analysis problem for library security is different from the network and web testing problem. If you ever build a code analysis capability for finding vulnerabilities in library code, I would be very interested.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

For library security analysis, hard to put a number on it. The market is less developed. Probably \$200 to \$400 a month if the capability were there.

#68

Axel Johansson

Bug Bounty Researcher

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I am based in Sweden and I do bug bounty full time. I specialize in subdomain takeover and DNS-based vulnerabilities. It is a specific niche but one where I have developed repeatable methodology and good tools.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

The manual verification step. Subdomain takeover candidates require individual verification to confirm they are actually exploitable -- a DNS entry pointing to an unclaimed resource does not always mean takeover is possible. That verification step is time consuming.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

I use Subfinder, DNSRecon, custom tools. I would consider an AI tool that automates the verification step for subdomain takeover candidates.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

If it can automate the verification of subdomain takeover candidates -- not just find the DNS misconfigurations but actually confirm exploitability -- that is directly useful. That is the most tedious part of my workflow.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

Per scan or per target makes sense for my use case. Maybe \$15 to \$25 per domain to run the full subdomain takeover analysis. Or \$200 to \$250 a month for the volume I run.

#69

Tasha Williams

Independent Penetration Tester

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I do private bug bounty and a few consulting clients on the side. Web applications are my focus. I have been doing this for four years and I have a few areas where I consistently find bugs -- OAuth implementations and GraphQL APIs.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

The repetitive setup work before I can get into actual testing. Every new target requires reconnaissance, understanding the tech stack, mapping endpoints. That setup phase is mechanical and I would love to automate it.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

Burp, Nuclei, some custom GraphQL tools I wrote. I have not found a good automated GraphQL testing tool.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

GraphQL testing automation would be directly useful. I spend a lot of time manually introspecting schemas and crafting queries. A tool that can automate the introspection-to-attack-path workflow would save real time.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

\$250 to \$400 a month for bug bounty use. GraphQL-specific capability would justify a higher price for me.

#70

Ravi Krishnamurthy

Bug Bounty Hunter

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I do bug bounty as a side income while working a day job in software development. Weekends and evenings mostly. I focus on the programs I know best -- the ones where my development background helps me understand the codebase.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

Time is my primary constraint. I have maybe 15 hours a week for security research. Anything that makes those hours more productive is valuable.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

I use Burp scanner in passive mode during normal browsing of target applications and then actively test anything that looks interesting. The passive approach fits my limited time.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

A time-efficient tool is the key attribute for me. If I can point it at a target, have it run overnight, and come back to a prioritized list of things worth investigating manually -- that is exactly what my workflow needs.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

Monthly \$200 to \$300 is my budget for this. I cannot justify more on a side project even if the ROI is there.

#71

Isla Campbell

Independent Security Researcher

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I research security vulnerabilities in consumer devices -- smart home products, wearables, consumer routers. I find bugs, responsibly disclose them, and I have received bounties from a few hardware vendors. It is a niche that most researchers ignore.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

Hardware vendors are even harder to work with than software vendors on responsible disclosure. The timelines are longer and the fix deployment is much slower -- firmware updates take months to reach devices.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

Firmware analysis tools -- Binwalk, radare2 -- and some network protocol analysis. The AI pentest tools are not relevant to hardware security.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

Not directly applicable but the network-facing services on consumer devices are testable with standard tooling. If it could identify vulnerabilities in the network-facing interfaces of embedded devices, there is a use case.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

Hardware security is a different market. I would pay \$200 to \$300 for network-interface testing capability on embedded devices.

#72

Diego Herrera

Bug Bounty Researcher

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

Full-time bug bounty, focused on Latin American programs -- startups, fintech, e-commerce. The programs are less mature which means less competition and more findings, but the payouts are lower and the response times are longer.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

Response time from programs is my biggest frustration. I submit a critical finding and wait three weeks to hear back. The uncertainty is stressful and it affects cash flow.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

Standard tooling. The AI platforms I know are aimed at the US market and the programs I work on are not the ones they demo against.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

If it could find bugs in less mature web applications -- the kind of basic injection and access control issues that are still out there in Latin American startups -- it would be directly useful. The finding density in my target programs is higher than mature US programs.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

Regional pricing matters a lot to me. US pricing is too high for the payout levels on Latin American programs. \$100 to \$200 a month would be my range.

#73

Naomi Clarke

Independent Penetration Tester

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I do private pentest consulting and occasional bug bounty. My specialty is authorization and access control -- IDOR, BFLA, privilege escalation in web apps. I have a systematic methodology for testing every user role against every resource in an application.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

The combinatorial problem in authorization testing. If an application has ten user roles and fifty resources, I need to check all combinations. That is 500 test cases and most of them need to be done manually because the context matters.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

Burp Suite is essential for me. I have some custom extensions for tracking authorization test cases. I have not found an automated tool that handles IDOR and BFLA testing well.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

Authorization testing automation is a genuinely hard problem that nobody has solved well. If you can do it -- understand the data model, enumerate resources, test access across roles -- that is a meaningful capability. I would want to validate it extensively before trusting it.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

\$400 to \$600 a month if the authorization testing is actually good. That is the holy grail of web app automation.

#74

Liam Donovan

Bug Bounty Hunter

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I do bug bounty on the side -- evenings and weekends. Web application focus, broad coverage rather than deep specialty. I run a lot of targets and pick up the things automated tools find that the program has not fixed yet.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

The signal-to-noise ratio of automated scanning on mature programs. Most of what Nuclei finds on a mature program is already known and fixed. Finding something genuinely new requires more manual effort than I have time for.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

Nuclei, Burp, some custom scripts. I would try any tool that claims to improve bug bounty hit rate.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

If it can find bugs that Nuclei misses on mature programs, I am interested. That is the hard part -- finding novel bugs on heavily tested targets. If it is just running existing checks faster, that is not differentiated enough.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

Low monthly cost is important for side-project use. \$100 to \$200 a month, or per scan in the \$20 to \$30 range.

#75

Bianca Romano

Independent Security Researcher

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I focus on privacy vulnerabilities -- data exposure, excessive data collection, improper data retention. It is a different frame than traditional pentesting. I am looking for what data is exposed or collected inappropriately, not just what can be exploited.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

Privacy research is hard to monetize. Some programs include privacy issues in scope, many do not. The regulatory angle -- GDPR enforcement -- is an alternative path but slow.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

I use data flow analysis tools and some custom scripts for identifying data exposure. The pentesting tools are not really designed for privacy analysis.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

Privacy-focused testing capability -- finding PII exposure, excessive data collection, improper data sharing -- would be interesting if it existed. That is a different product from attack-focused pentesting but there is market need.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

Privacy assessment market is developing. \$200 to \$400 a month for a privacy-focused capability.

#76

Max Bauer

Independent Security Consultant

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

Solo consulting, mostly SMB clients. I do their annual pentest, help them with remediation, maybe do a follow-up assessment. The relationship is long-term and the work is not just technical -- I am the client's security advisor for the year.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

Pricing pressure from commodity pentest vendors. There are firms selling network pentests for \$5,000 and clients ask me why I charge more. Differentiating on quality is the answer but it requires educating clients on what quality actually means.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

I use standard tooling, nothing exotic. I have looked at AI platforms to see if they would lower my costs enough to compete on price. Most of them are still too expensive for what they provide.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

If it reduced my cost per engagement significantly, I could compete on price without sacrificing margin. That is the business case for me. Technically I would need it to produce clean, accurate findings -- SMB clients cannot afford false positive remediation.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

I need to be able to pass the cost through to clients or absorb it in margin. At \$300 to \$400 a month with good accuracy, the economics could work. Higher than that and the margin story breaks at SMB pricing.

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I left a large consulting firm two years ago to go independent. Less structure, more interesting clients, better margins. I do external and web app testing, mostly for clients who were referred by existing clients. Word of mouth is my sales engine.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

Sales. I am good at testing but not naturally a salesperson. Building a pipeline of new clients requires effort that takes time away from billable work. The transition from employee to independent required developing business skills I did not have.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

Standard tooling. I have not invested in expensive platforms because my margins need to stay healthy. I keep costs low.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

If it reduced my time per engagement by 30%, I could take on more clients or have more margin per client. Both outcomes are good. I would need a trial to validate the time savings before committing.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

At \$300 to \$500 a month I can make the math work. I do six engagements a month at SMB pricing. If the tool saves me three hours per engagement at my rate, it pays for itself several times over.

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I do red team work independently which is uncommon. Most red team is done by teams. I position myself as a solo senior operator who can do a one-person red team exercise for clients who cannot afford a full team but want something more sophisticated than a standard pentest.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

Selling solo red team is harder than selling a team engagement. Clients want the comfort of knowing there are multiple brains on their assessment. I have to sell my individual track record hard.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

I use everything -- Cobalt Strike, Sliver, Metasploit, custom C2. No AI platforms in my workflow yet. I am conservative about adding new tools because OPSEC depends on knowing exactly what your tools do.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

For solo red team work, an AI that could handle some of the parallelizable tasks -- running recon and initial scanning while I am focused on initial access, for example -- would effectively give me a second operator. That is compelling. I would need to trust the OPSEC profile completely first.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

Monthly \$700 to \$900 if the OPSEC is solid. For red team work that is a reasonable investment -- one extra engagement pays for several months of the tool.

#79

Mei Liu

Freelance Security Researcher

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I do web application security research and consulting. Based in Singapore, clients across Asia-Pacific. Mix of consulting engagements and some bug bounty on the side. The Asia-Pacific market has its own dynamics -- fast-growing startup ecosystem with sometimes immature security practices.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

Client education. A lot of my time is spent explaining why findings matter, not just what they are. Security literacy is lower in some client segments here and the reporting has to meet clients where they are.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

Standard tooling. The AI platforms are mostly designed and priced for US markets.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

If it could generate client-appropriate reports automatically -- executive summary in business language, technical detail for the development team, remediation guidance at the right level for the client's technical capacity -- that is genuinely valuable. That tailoring currently takes significant time.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

For the Asia-Pacific market, regional pricing would matter. US SaaS pricing is often 2x to 3x what the market bears here. \$250 to \$400 a month would be workable.

#80

Ted Wakefield

Independent Offensive Security Consultant

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I have been consulting independently for twelve years. Mostly financial services and insurance clients, external testing and some application security. Long client relationships -- I have clients I have worked with for eight years.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

The hardest thing for a long-tenure independent is staying current. Twelve years in, the techniques change but you have to fight the tendency to rely on what you know. The field moves and I have to move with it.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

I have updated my tooling significantly over the years and I am not resistant to new tools. I adopted Nuclei early, I added BloodHound when it came out. I evaluate new tools on results, not on hype.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

I would evaluate it seriously. My clients trust my judgment on tooling and I can introduce new tools into my workflow if they perform. I would run it in parallel with my existing approach on two or three engagements before making it primary.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

Monthly \$600 to \$800. At my rate and volume, that is a small cost if the tool earns its place.

#81

Gabrielle Fontaine

Freelance Penetration Tester

- Q1** *Walk me through what a typical engagement looks like for you, start to finish.*
I am in France doing freelance work. Web application and API testing primarily. I work with a network of other independents so I can assemble a team when a client needs more capacity than I can provide alone.
- Q2** *What takes the most time or causes the most friction in your day-to-day work?*
The administrative work of running an independent practice. Invoicing, contracts, taxes, business development -- all of this takes time that does not produce billable hours.
- Q3** *Have you used any AI-based or automated pentest tools? What was your experience?*
Standard European tooling. I track new tools but I am selective about what I actually incorporate into my workflow.
- Q4** *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*
If it handles the mechanical testing phases, I can bill for the analysis and strategic advice which is higher value work. That reframing of what a freelancer sells -- from hours of testing to insights and expertise -- is interesting strategically.
- Q5** *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*
At \$350 to \$500 a month it is financially justifiable if the time savings are real. I am skeptical of demos but open to a proper trial.

#82

Roland Steele

Independent Security Consultant

- Q1** *Walk me through what a typical engagement looks like for you, start to finish.*
Twenty years in security, last seven as an independent. I do strategy, architecture review, and technical testing. The breadth is my selling point -- I can assess the whole security picture, not just run a scan. My clients pay for perspective, not just findings.
- Q2** *What takes the most time or causes the most friction in your day-to-day work?*
The market devaluation of technical pentesting. Commodity testing prices have dropped significantly and clients sometimes cannot see the difference between a \$5,000 automated scan and a \$20,000 senior practitioner engagement. That gap is real but hard to communicate.
- Q3** *Have you used any AI-based or automated pentest tools? What was your experience?*
I have incorporated automation into my workflow throughout my career. The tools change but the philosophy -- use automation for the mechanical, human judgment for the strategic -- has been constant.
- Q4** *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*
I am not opposed to it but I am selective. If it genuinely makes me more efficient at the mechanical work and the output quality is something I can stand behind with a client, it earns a place in my workflow. Twenty years of reputation is on the line with every engagement.
- Q5** *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*
Monthly \$600 to \$800. At my billing rate and client expectations, the economics are straightforward if the tool performs.

#83

Anika Johanssen

Freelance Red Team Consultant

- Q1** *Walk me through what a typical engagement looks like for you, start to finish.*
I specialize in social engineering as part of red team engagements. Phishing, vishing, pretexting, physical. The technical work is the smaller part of my engagements -- the human attack surface is what I focus on.

- Q2** *What takes the most time or causes the most friction in your day-to-day work?*
Social engineering results are hard to measure. Getting someone to click a link is a data point but what does it mean strategically? The narrative around the results is as important as the results themselves.
- Q3** *Have you used any AI-based or automated pentest tools? What was your experience?*
Not really relevant to social engineering work. My tools are a phishing platform, a VoIP setup, and some physical bypass tools. None of that is automated in the AI sense.
- Q4** *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*
If it could handle the technical component of an engagement while I focus on the social engineering, that parallel operation would be valuable. I would hand the technical recon off to it and focus on the human side.
- Q5** *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*
For a tool that handles the technical side so I can focus on social engineering, \$500 to \$700 a month. Good division of labor.

#84

Colin Fraser

Independent Penetration Tester

- Q1** *Walk me through what a typical engagement looks like for you, start to finish.*
Solo practitioner in Scotland. Mix of clients -- small banks, local government, some tech companies. The range of clients means a range of technical environments and I have to adapt my approach.
- Q2** *What takes the most time or causes the most friction in your day-to-day work?*
Finding good clients is the hardest part of independent work. The clients worth having are not the ones who are shopping on price. Getting in front of the right buyers without spending all my time on sales is a constant challenge.
- Q3** *Have you used any AI-based or automated pentest tools? What was your experience?*
Standard tooling, same as most. I have used some automation to help manage multiple concurrent small engagements.
- Q4** *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*
For managing multiple concurrent engagements efficiently, automation would help significantly. I sometimes run three small engagements at once and keeping them all moving without things falling through the cracks is difficult.
- Q5** *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*
Monthly \$350 to \$500. UK market pricing. I need the economics to work with the rates I charge here.

#85

Petra Hoffman

Freelance Security Researcher

- Q1** *Walk me through what a typical engagement looks like for you, start to finish.*
I specialize in vulnerability research for software vendors -- finding bugs in their products and working with their security teams on fixes. I mostly do it under NDA with coordinated disclosure and occasionally there are bounties. It is niche but it suits how I like to work.
- Q2** *What takes the most time or causes the most friction in your day-to-day work?*
The long disclosure timelines. Between finding a bug, validating it, writing the report, coordinating with the vendor, and waiting for the fix -- we are often talking about six to twelve months from discovery to public disclosure. That is slow.
- Q3** *Have you used any AI-based or automated pentest tools? What was your experience?*
Fuzzing and static analysis are my primary tools. The AI pentest platforms are not relevant to product security research.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

Not directly applicable but if you ever build code analysis capabilities, product security research is a meaningful market. Right now it is underserved by commercial tooling.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

For product security research capability, I would pay \$300 to \$500 a month. The market for this is real.

#86

Marco Barone

Independent Offensive Security Consultant

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I am in Italy, working mostly with Italian and Southern European clients. Mix of network, web, and some OT testing for manufacturing clients. Italy has a lot of manufacturing sector work which has interesting ICS/SCADA attack surfaces.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

ICS/SCADA testing is extremely risk-sensitive. You cannot afford a mistake near production equipment. Every action requires explicit authorization and the testing has to be conservative. That caution is right but it makes the work slow.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

Standard tooling for the IT side. For OT I use specialized tools and custom scripts. Nothing AI-powered near OT.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

For the IT side of my work, yes. For anything near ICS/SCADA, no -- the risk profile is too high for autonomous systems. The IT and OT boundary testing is where I would use it.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

Monthly \$500 to \$700 for IT-focused capability. OT-specific capability would need to be priced and designed separately.

#87

Caitlin Burke

Freelance Penetration Tester

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I focus on startups and early-stage companies -- companies doing their first security assessment. They often do not know what they need and part of my job is educating them on what a pentest is, what it covers, and what they should do with the results.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

Client expectation setting. Startups sometimes expect a pentest to be a clean bill of health. Explaining that findings are expected and valuable, not a failure, is important work.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

Standard tooling. Startup clients often want the report to come out of a recognized tool so they can show it to investors or enterprise customers. Brand recognition of the tooling matters to them in a way it does not for mature enterprises.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

For startup-focused work, a tool that produces investor-ready or sales-enablement-friendly reports would be useful. The technical output has to translate into something that helps the startup close deals.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

\$300 to \$400 a month. Startup client pricing is compressed and margins are tight.

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I am in Ghana and I consult for clients across West Africa. The regional market is developing quickly -- fintech, telecom, government digital transformation. Security maturity varies widely.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

Infrastructure limitations affect testing. Reliable network connectivity and compute resources are not always what they would be in Western markets. Some of my tooling choices are made on bandwidth and reliability grounds.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

I use lightweight tooling that works reliably on variable connectivity. Not all the cloud-based platforms work well in my environment.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

Offline capability or at least graceful degradation on poor connectivity would be important for my context. If it requires persistent high-bandwidth connection it is not workable for some of my engagements.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

Regional pricing is essential. US SaaS pricing is not calibrated to African market rates. \$100 to \$200 a month would be workable. \$500 would not be.

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I left a Big 4 firm two years ago to go independent. The firm was doing high-quality work but the overhead and politics were exhausting. Independent work is more direct -- I deliver, the client benefits, I get paid.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

The transition from firm to independent required developing a personal brand. Inside a large firm the brand does the selling. Independent, you are the brand and you have to build that from scratch.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

At the firm we had enterprise tooling. Going independent I had to rebuild my toolkit on a budget. I know what good tooling costs because I came from an environment where budget was not a constraint.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

From my firm background I know what the enterprise buyers want -- complete audit trail, defensible findings, clean report format. If this platform can deliver that at a price accessible to an independent consultant, that is the market opportunity.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

Monthly \$500 to \$700 for the capability profile you are describing. That is accessible for an independent without enterprise budget.

- Q1** *Walk me through what a typical engagement looks like for you, start to finish.*
I am in Belgium and I do penetration testing for clients in the EU financial sector. The regulatory environment is dense -- DORA is the latest addition to the alphabet soup. Every engagement requires more regulatory context than technical work some days.
- Q2** *What takes the most time or causes the most friction in your day-to-day work?*
DORA compliance. The Digital Operational Resilience Act has created new requirements for financial entities around penetration testing. Understanding what DORA actually requires and how to satisfy it is still being figured out across the industry.
- Q3** *Have you used any AI-based or automated pentest tools? What was your experience?*
Standard tooling plus whatever the regulatory framework requires in terms of documentation. I have been spending more time on documentation tools than technical tools lately.
- Q4** *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*
If it produced DORA-compliant documentation automatically -- the specific reporting formats and control mappings that DORA requires -- that would be immediately valuable. That is a concrete compliance need right now.
- Q5** *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*
For DORA-aware capability, \$800 to \$1,000 a month. The regulatory compliance market pays well and the cost is easily justified to financial sector clients.
-

#91

Sandra Kaufmann

Corporate Red Team Manager

- Q1** *Walk me through what a typical engagement looks like for you, start to finish.*
I manage the red team for a large financial institution. We run three to four exercises per year, each two to four weeks long. Everything is carefully planned -- objectives defined with the CISO, rules of engagement reviewed by legal, deconfliction with the blue team at defined intervals. The exercises are as much about the blue team's development as they are about finding vulnerabilities.
- Q2** *What takes the most time or causes the most friction in your day-to-day work?*
Stakeholder alignment is the hardest part of corporate red team. Legal, compliance, the CISO, the operational teams whose systems we are testing -- everyone has concerns and requirements that have to be balanced. Getting all of those aligned before we start takes weeks.
- Q3** *Have you used any AI-based or automated pentest tools? What was your experience?*
We use commercial tooling that our legal team has reviewed and approved. The procurement and approval process for new tools is significant -- security, privacy, data handling all have to be evaluated. AI platforms have not been through our procurement process yet.
- Q4** *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*
The procurement and legal review process is real and it takes time. If you want to sell to large financial institutions, you need to be able to answer detailed questions about data handling, logging, liability, and regulatory compliance. Those answers need to exist before procurement conversations can start.
- Q5** *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*
Corporate red team budgets are annual and run through proper procurement. Individual tool budgets of \$15,000 to \$25,000 per year are possible if the tool is approved. The approval process is the real barrier, not the budget.
-

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

We are a six-person red team at a large technology company. We run continuous testing -- always something in progress -- and we do a mix of internal exercises and external attack surface validation. The team specializes by domain: one person on AD, one on cloud, one on applications, one on social engineering.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

Coverage at scale. The organization has thousands of assets across multiple cloud environments and regions. Full coverage is impossible with the headcount we have and we have to make strategic choices about where to focus.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

We use commercial tooling for most functions. I have been following the AI pentest space and I am interested but cautious. The enterprise security context raises additional questions that consumer and SMB tools do not have to answer.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

For an enterprise buyer the questions are: where does our data go, how is it secured, what certifications does the vendor have, can you meet our contractual requirements around data handling, and who is liable when something goes wrong. Those are prerequisites, not nice-to-haves.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

Enterprise licensing is per-seat or enterprise-wide. If you are going to sell to large tech companies, you need a procurement-friendly packaging. \$100,000 to \$200,000 per year for an enterprise-wide license is in the range.

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I lead offensive security for a healthcare technology company. HIPAA context shapes everything we do -- we test carefully, we document everything, and our findings have to be in language that the compliance team can work with. The clinical systems add an additional layer of sensitivity because availability is as important as security.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

The tension between thorough testing and patient safety. We cannot test in a way that risks availability of clinical systems. That limits what we can do and requires very specific scope boundaries and testing windows.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

We use approved tooling that has been reviewed for HIPAA applicability. New tools go through security and compliance review before we use them.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

For healthcare, the tool itself has to meet HIPAA requirements -- data handling, access controls, audit logging. If it touches PHI during testing or stores any data that could be tied to patients, that is an immediate regulatory issue. Can it operate without retaining any scan data beyond what is needed for the current session?

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

Healthcare enterprise pricing is significant. A tool that meets our compliance requirements could justify \$50,000 to \$100,000 per year. The compliance overhead makes every compliant solution more valuable.

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I run a red team function inside a major technology company. We are well-resourced compared to most -- good tooling budget, talented team, executive support. Our challenge is scale -- the attack surface is enormous and growing.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

The attack surface growth outpaces our testing capacity. We add more coverage of existing assets and the organization adds more assets faster. It is a constant race.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

We use all the major commercial tools and have built significant custom tooling. I have been watching the AI pentest space and I think we are 12 to 18 months from something that is ready for enterprise use. The current tools have too many rough edges.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

For an enterprise buyer, the tool needs to be production-grade. That means reliability, accurate findings, complete logging, and a vendor who can support enterprise SLAs. If you can get there, the opportunity in enterprise is significant. Right now most AI security tools are still SMB-quality.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

Enterprise-scale pricing would be \$150,000 to \$300,000 per year for an organization our size. We would need a pilot agreement with defined success metrics before any commitment.

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I direct red team operations for a global insurance company. I have a team of eight across three regions and we support the global security program. Regulatory requirements vary by region and we have to produce outputs that satisfy regulators in multiple jurisdictions.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

Multi-jurisdiction compliance is genuinely complex. The same engagement has to produce findings and documentation that satisfies requirements in the EU, the US, and sometimes Asia-Pacific simultaneously. The mapping work is significant.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

We use enterprise-grade tooling with appropriate vendor agreements. We have gone through the evaluation of several commercial platforms and the shortcomings are usually on the compliance and documentation side -- technically capable but insufficient for our reporting requirements.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

Global regulatory compliance would be the defining capability for us. If it can produce findings that map to multiple regulatory frameworks simultaneously -- NIST, SOC 2, GDPR, and Solvency II as an example -- that is a meaningful differentiator. I have not seen anything that does that well.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

For a global insurance company, \$200,000 to \$400,000 per year is the enterprise range if the regulatory compliance piece is solid. Multi-region data handling is also a requirement.

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I am an individual contributor on a large enterprise red team. My specialty is cloud -- AWS, Azure, GCP, and cloud-to-on-prem pivoting. The attack surface is interesting and grows constantly.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

Cloud environments change fast and the security model changes with them. New services introduce new attack surfaces and I have to stay current across three major cloud providers. That knowledge maintenance is significant.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

We use ScoutSuite, Prowler, and a lot of custom tooling. The AI platforms I have evaluated for cloud are better than they were a year ago but still miss the sophisticated IAM attack paths.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

For cloud-specific capability -- and I mean genuinely understanding IAM trust chains, not just flagging public resources -- I would advocate for it internally. The current tooling gap in sophisticated cloud attack path analysis is real.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

Enterprise licensing is what applies to me. My advocacy counts but the decision is made above me. I can tell you what a senior practitioner would find valuable, which informs the feature roadmap.

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I lead a red team at a semiconductor company. We have a mix of corporate IT and research network -- the research network has IP that is genuinely valuable to nation-state adversaries. Our threat model is sophisticated and our testing reflects that.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

The sophistication of our threat model means we are simulating APT behavior, not commodity attackers. That requires a level of operational complexity and patience that is hard to maintain over long exercises.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

We use advanced tooling -- Cobalt Strike, some nation-state-quality implants for testing purposes. We also use open source heavily because transparency in tooling is important to us.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

For APT simulation, the OPSEC requirements are strict. A tool that generates noise that no real APT would generate is worse than no tool. The critical question for us is how the platform's traffic and behavior compares to known threat actor signatures.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

For advanced threat simulation tooling, budget is not the primary constraint. Capability and OPSEC are the constraints. We would pay \$200,000 to \$300,000 per year for something that genuinely advances our APT simulation capability.

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I am an internal security consultant at a large manufacturing company. I support the red team function but also advise on broader security architecture. The manufacturing context has OT security complexity that is underappreciated in most security frameworks.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

Getting the IT and OT security teams to collaborate. They have different cultures, different risk tolerances, and different tooling philosophies. Bridging that gap is as much a people problem as a technical one.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

For IT we use standard tooling. For OT we use specialized tools and we are very conservative. I have not evaluated AI platforms for either.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

For IT side of our environment, a tool that can manage large-scale scanning across a complex manufacturing network -- multiple sites, legacy systems, diverse protocols -- would be useful. The OT side remains manual by choice.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

Enterprise licensing, probably \$100,000 to \$150,000 per year if it handles complex multi-site manufacturing environments well.

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I manage a corporate red team for a large retail company. The attack surface is primarily web and point-of-sale -- PCI DSS is the dominant regulatory framework. We test continuously and have a close relationship with the blue team.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

The pace of change in the retail attack surface. E-commerce grows constantly, new payment integrations are added, the mobile app gets new features. Testing keeps up for a while and then there is a sprint of development that moves the surface ahead of our testing.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

We use standard tooling with PCI-specific configuration. New tools go through our PCI QSA for review before we use them in a cardholder data environment.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

For retail, PCI compliance in the tooling is essential. The QSA review process takes time but it is not optional. If you have completed PCI assessments of the platform or can provide documentation that supports our QSA review, that accelerates the adoption process.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

PCI-approved tooling at enterprise scale, probably \$75,000 to \$150,000 per year. The QSA review is a hurdle but one the tool only has to clear once.

Q1 *Walk me through what a typical engagement looks like for you, start to finish.*

I lead red team for a large energy company. Critical infrastructure context shapes everything -- we have OT, IT, and corporate environments and they are interconnected in ways that create interesting but dangerous attack paths.

Q2 *What takes the most time or causes the most friction in your day-to-day work?*

The regulatory scrutiny on critical infrastructure is significant and growing. NERC CIP, TSA directives, and sector-specific requirements all apply and they all require documentation of our testing activities. The compliance documentation burden is substantial.

Q3 *Have you used any AI-based or automated pentest tools? What was your experience?*

We use approved tooling that has been reviewed for critical infrastructure use. The bar is high and the review process is thorough.

Q4 *If a platform could run a full autonomous pentest -- recon through post-exploitation -- under your oversight, would you use it? What would you need to see before you trusted it?*

Critical infrastructure has specific requirements that go beyond standard enterprise. The tool would need to demonstrate that it cannot be weaponized against critical infrastructure -- that the safety guardrails are robust enough that a compromised or misconfigured tool cannot cause physical impact. That is a higher bar than SOC 2.

Q5 *What would fair pricing look like for something like this? Per scan, monthly sub, something else?*

Critical infrastructure procurement is slow and thorough. \$200,000 to \$500,000 per year for the right capability, but the evaluation period alone could take six to twelve months. If you are selling to this sector, plan for a long sales cycle.
